

Web Application Vulnerability Assessment Report

Project Information

Field	Details
Project Title	Web Application Vulnerability Assessment
Target Application	Flask Task Tracker Application
Assessment Type	Authorized Web Application Security Assessment
Assessor	Arz
Date	15 May 2026
Environment	Kali Linux

1. Executive Summary

This report documents the results of a web application vulnerability assessment conducted on a self-owned Flask-based task tracking application hosted on Render infrastructure. The assessment included reconnaissance, enumeration, automated vulnerability scanning, and manual testing using industry-standard cybersecurity tools.

The purpose of this assessment was to identify common web application security weaknesses, evaluate application behavior against malicious input, and document the overall security posture of the application.

The assessment identified informational findings related to infrastructure fingerprinting and HTTP headers. Manual testing for common injection vulnerabilities such as Cross-Site Scripting (XSS) and HTML Injection did not reveal any critical vulnerabilities. The application handled tested payloads safely and rendered malicious input as plain text.

No critical vulnerabilities were identified during the assessment.

2. Scope of Assessment

Authorized Scope

Testing was performed only on a self-owned and authorized web application for educational and internship purposes.

Target Information

Item	Details
Application	Flask Task Tracker
Hosting Provider	Render
Reverse Proxy/CDN	Cloudflare
Protocols Tested	HTTP / HTTPS

Assessment Limitations

- Assessment focused primarily on beginner/intermediate-level web application testing.
 - No destructive testing or denial-of-service testing was performed.
 - Cloudflare infrastructure limited certain automated scanning operations.
 - Full authenticated role-based access testing was outside assessment scope.
-

3. Methodology

The following methodology was used during the assessment process:

Reconnaissance



Enumeration



Automated Vulnerability Scanning



Manual Testing



Analysis & Reporting

3.1 Reconnaissance

Initial reconnaissance was conducted to identify:

- Open ports
- Running services
- Hosting technologies
- Reverse proxy infrastructure

3.2 Enumeration

Enumeration activities included:

- Web technology fingerprinting
- Directory discovery
- Header analysis

3.3 Automated Vulnerability Scanning

Automated scanning tools were used to identify:

- Misconfigurations
- Exposed headers
- Known weak configurations
- Common web vulnerabilities

3.4 Manual Testing

Manual testing was performed using Burp Suite and browser-based interaction to validate:

- Input validation
 - HTML Injection handling
 - Cross-Site Scripting (XSS)
 - Error handling behavior
 - Application response to special characters
-

4. Tools Used

Tool	Purpose
Nmap	Port scanning and service detection
WhatWeb	Web technology fingerprinting
Nikto	Web vulnerability scanning
Gobuster	Directory enumeration
Burp Suite Community Edition	Manual web application testing
Firefox	Browser-based interaction testing

5. Assessment Results

5.1 Nmap Scan Results

Objective

Identify exposed ports and running services.

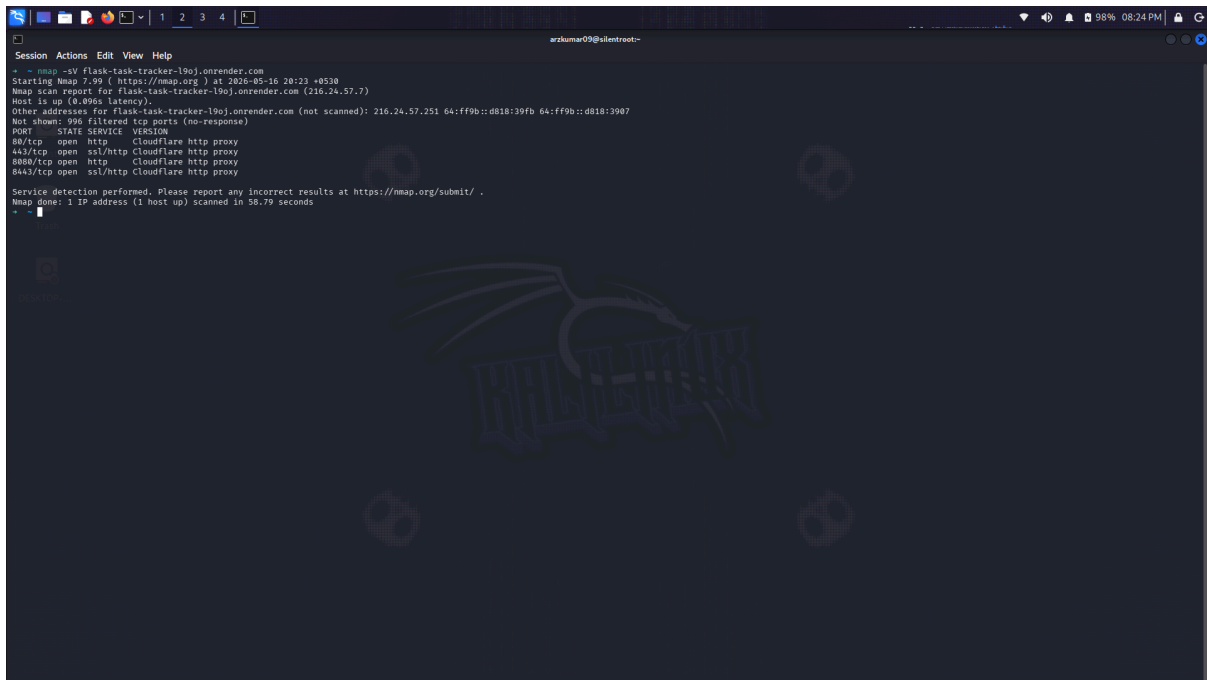
Key Findings

- HTTP and HTTPS services detected.
- Alternate web service ports identified.
- Cloudflare proxy infrastructure detected.

Observations

The target application appeared to be protected behind Cloudflare proxy infrastructure, limiting direct exposure of backend services.

Screenshot



```
Session Actions Edit View Help
- nmap -sV flask-task-tracker-190j.onrender.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-16 20:23 +0530
Nmap scan report for flask-task-tracker-190j.onrender.com (216.24.57.7)
Host is up (0.090s latency).
Other addresses for flask-task-tracker-190j.onrender.com (not scanned): 216.24.57.251 64:ff9b::db18:39fb 64:ff9b::db18:3907
Not shown: 990 filtered tcp ports (no-response)
PORT      State SERVICE VERSION
80/tcp    open  http      Cloudflare http proxy
443/tcp   open  ssl/http  Cloudflare http proxy
8080/tcp   open  http      Cloudflare http proxy
8443/tcp   open  ssl/http  Cloudflare http proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 56.79 seconds
```

5.2 WhatWeb Fingerprinting Results

Objective

Identify technologies used by the application.

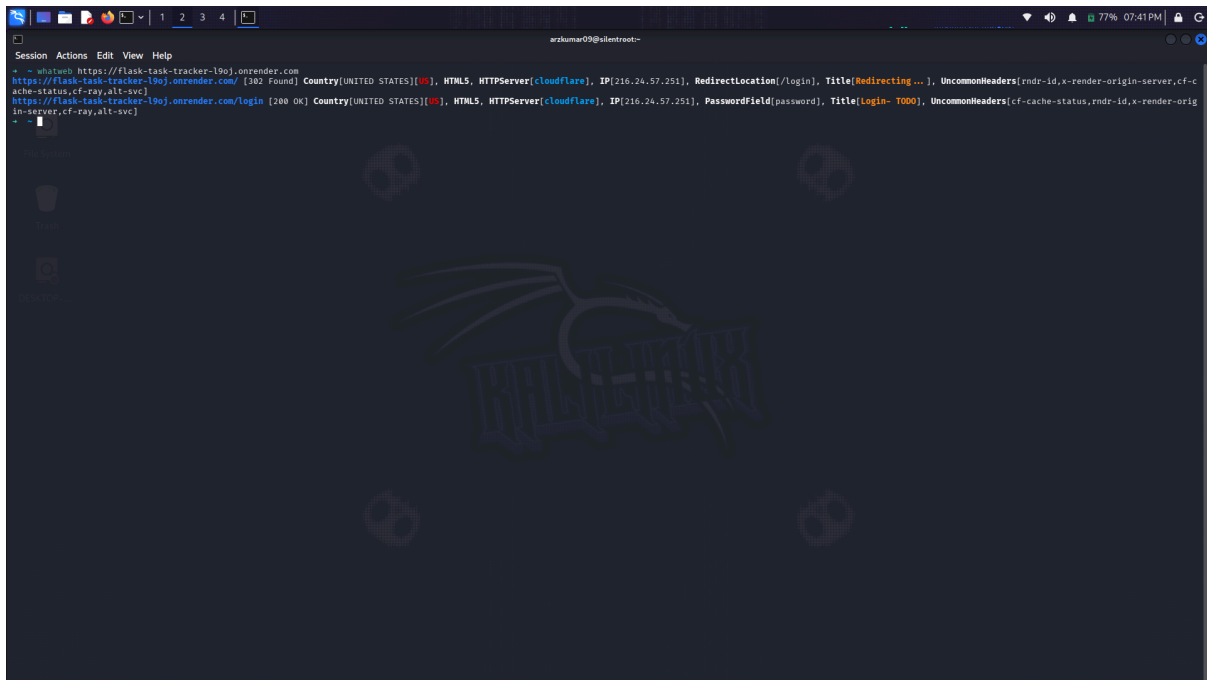
Key Findings

- Flask-related infrastructure identified.
- Cloudflare reverse proxy detected.
- Render hosting environment identified.

Observations

Technology fingerprinting successfully identified application hosting and reverse proxy infrastructure.

Screenshot



5.3 Gobuster Enumeration Results

Objective

Identify accessible directories and hidden endpoints.

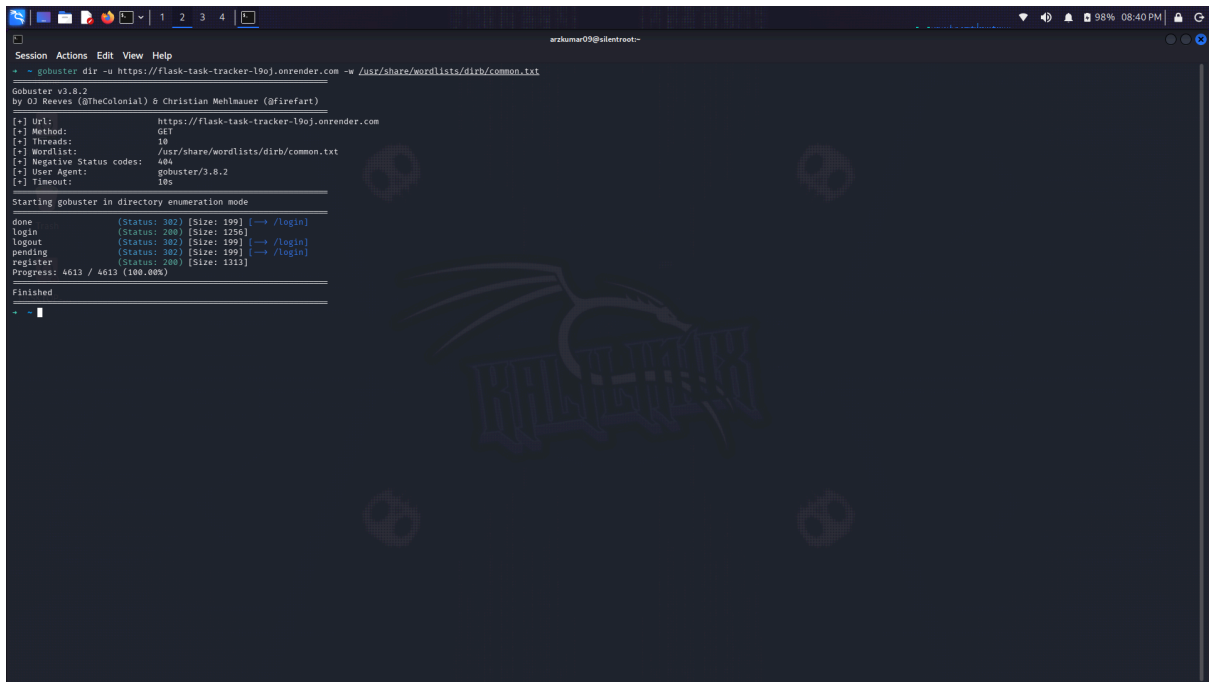
Key Findings

- No highly sensitive directories identified.
- Enumeration completed successfully.

Observations

No exposed administrative or backup directories were identified during enumeration.

Screenshot



5.4 Nikto Scan Results

Objective

Identify common web server misconfigurations and vulnerabilities.

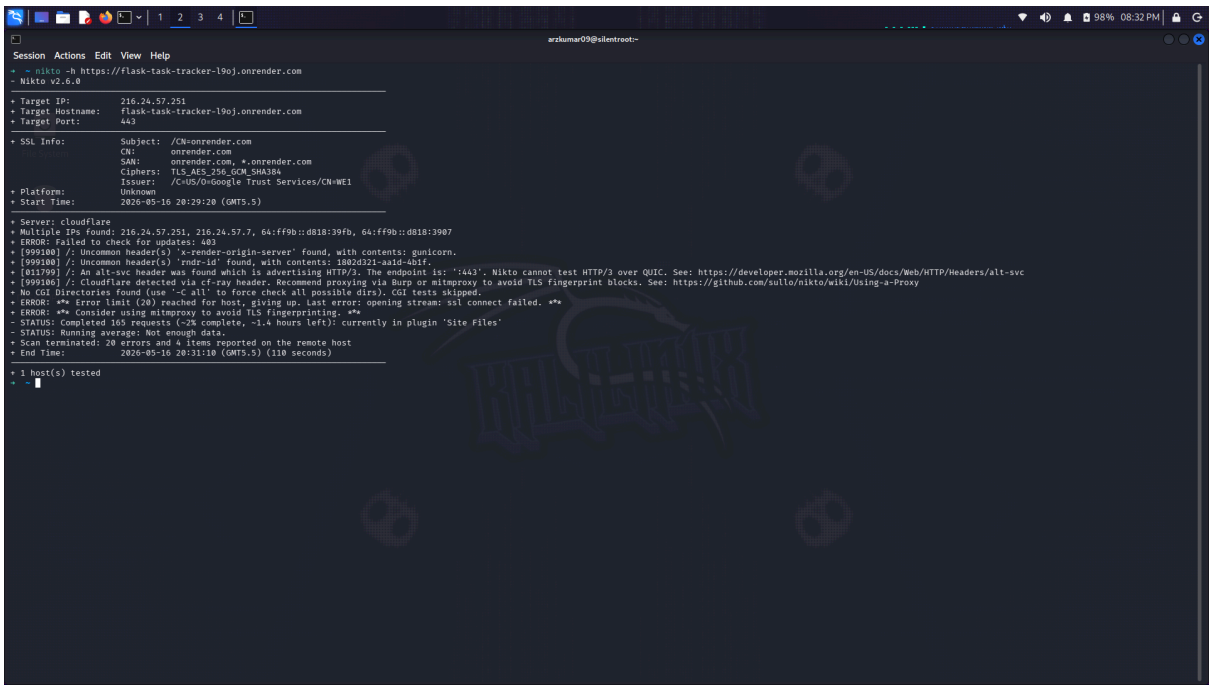
Key Findings

Finding	Severity
Cloudflare infrastructure detected	Informational
Gunicorn header identified	Informational
HTTP/3 support detected	Informational
TLS interruptions during scan	Informational

Observations

Cloudflare infrastructure appeared to implement protections against aggressive automated scanning behavior, limiting full Nikto scan completion.

Screenshot



6. Manual Testing Results

Objective

Evaluate application behavior against malicious or unexpected user input.

Testing Performed

The following payloads were tested in task title and description fields:

HTML Injection Payload

<h1>AK</h1>

XSS Payload

<script>alert(1)</script>

Special Character Payloads

.....

< > ' " ; --

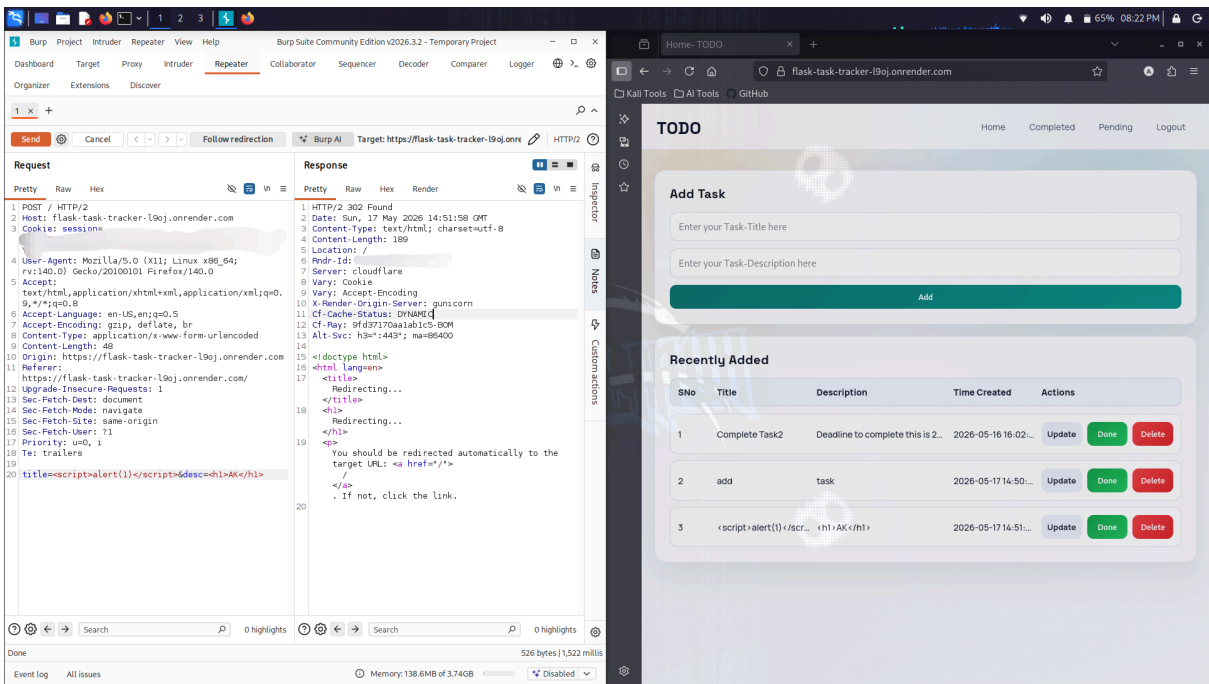
Observations

- Payloads were stored as plain text.
- No JavaScript execution occurred.
- No HTML rendering behavior was observed.
- No application crashes or internal error disclosures were identified.
- Input handling appeared stable during testing.

Security Interpretation

The application appeared to safely handle tested payloads using output escaping and input handling mechanisms. No evidence of reflected or stored Cross-Site Scripting (XSS) vulnerabilities was identified during testing.

Screenshot



7. Findings Summary

Severity	Finding	Status
Informational	Cloudflare reverse proxy detected	Identified
Informational	Gunicorn server header identified	Identified
Informational	HTTP/3 support advertised	Identified
Low	Automated scan interruptions due to proxy protections	Observed
Medium	XSS testing performed	No vulnerability identified
Informational	Input validation testing	Handled safely

8. Recommendations

The following recommendations are suggested to further improve application security posture:

1. Continue validating and sanitizing user input.
 2. Implement additional Content Security Policy (CSP) headers.
 3. Regularly update Flask dependencies and server packages.
 4. Perform periodic vulnerability assessments.
 5. Continue monitoring application logs for suspicious activity.
 6. Avoid exposing unnecessary response headers.
-

9. Conclusion

The web application vulnerability assessment was successfully completed using a combination of automated and manual testing techniques.

The application demonstrated stable handling of tested malicious payloads and did not exhibit obvious signs of common injection vulnerabilities during assessment.

No critical vulnerabilities were identified during testing.

The assessment also provided valuable insight into:

- Web application reconnaissance

- HTTP traffic analysis
 - Manual payload testing
 - Vulnerability scanning workflow
 - Security reporting practices
-

10. Appendix

Raw Scan Outputs

Include:

- nmap.txt
- nikto.txt
- gobuster.txt
- whatweb.txt

Screenshots

Include:

- Nmap Scan
 - WhatWeb Scan
 - Gobuster Results
 - Nikto Results
 - Burp HTTP History
 - Manual Testing Results
-

Disclaimer

This assessment was conducted strictly for authorized educational and internship purposes on a self-owned web application. No unauthorized systems were targeted during testing.